

건전한 운영리스크 관리원칙

제1장 총칙

1. **(목적)** 이 원칙은 세칙 <별표3> 241.나에 따른 건전한 운영리스크 관리 원칙을 정함을 목적으로 한다.
2. **(구성요소)** 이 원칙은 지배구조, 리스크관리 환경, 정보통신기술(ICT) 리스크관리, 영업연속성 계획 등, 그리고 공시로 구성되며 이 요소들을 개별적 접근이 아닌 운영리스크 관리 체계 등을 포함한 그룹의 전반적인 리스크 관리 체계에 통합한다.
3. **(적용범위)** 은행은 이 원칙을 은행의 규모, 리스크 수준, 영업활동의 복잡성 및 변동성 등을 감안하여 은행의 운영리스크 관리 체계에 적절히 반영할 수 있다. 은행이 운영리스크 관리 체계에서 일부 영업활동 및 자회사 등을 제외하는 경우, 제외된 영업활동 및 자회사가 전반적인 운영리스크 관리 체계에서 중요한 영향을 미치지 않는다는 것을 입증하여야 한다.

제2장 3단계 통제체계

4. **(3단계 통제체계 구축)** 은행은 운영리스크를 적절히 인식하고 관리하기 위하여 단위사업부문(재무·인사·IT 등 지원조직을 포함한다), 독립적인 운영리스크 관리부문(준법 조직을 포함한다) 및 내부감사(또는 유사한 독립적인 내부·외부조직을 포함한다. 이하 "내부감사"라 한다)로 구성되는 상호 견제와 균형의 원칙에 입각한 3단계 통제체계를 구축하여야 한다.
5. **(역할과 책임 부여)** 은행은 3단계 통제체계의 효과적인 작동을 위하여 단위사업부문, 독립적인 운영리스크 관리부문 및 내부감사 등 관련 부서에 역할과 책임을 명확히 부여하여야 한다. 다만, 만일 하나의 단위사업부문에 1차 및 2차 통제체계 역할을 모두 담당하는 경우, 2차 통제체계 역할의 독립성이 확보되어야 하며, 1차 및 2차 통제체계에 대한 역할과 책임을 명확히 구분하고 문서화하여야 한다.
6. **(건전한 리스크 관리문화 확립)** 은행은 3단계 통제체계에 예산·인력·교육 등을 적절히 지원하고, 운영리스크 관리 수준 제고를 위해 3단계 통제체계가 상호 협력할 수 있는 체계를 구축하는 등 조직 전체에 걸쳐 건전한 리스크 관리문화가 확립될 수 있도록 노력하여야 한다.
7. **(1차 통제체계)** 단위사업부문은 운영리스크 관리를 위하여 부문 내 모든 상품, 영업활동, 프로세스 및 시스템에 내재된 운영리스크를 인식·평가하고 관리할 책임이 있으며 구체적으로는 다음 사항을 포함한다.

가. 운영리스크 경감을 위한 통제 방법 수립 및 이에 대한 효과성 평가

나. 운영리스크를 인식·평가하는데 예산·인력·수단·교육 등의 충분 여부 보고

다. 정기적인 운영리스크 현황 모니터링·보고 및 한도 등 준수 점검

라. 잔여 운영리스크, 운영 손실 사건, 통제 결함, 부적절한 프로세스 및 한도 미준수에 대한 보고

8. **(2차 통제체계)** 독립적인 운영리스크 관리부문은 다음의 역할을 수행하여야 한다.

- 가. 단위사업부문의 운영리스크에 대한 이해도 제고 및 효과적인 운영리스크 평가를 위하여 단위사업부문에 적절한 자원·수단을 제공하고, 교육을 지속적으로 실시
- 나. 단위사업부문의 운영리스크 관리 적정성, 은행의 운영리스크 관리, 측정 및 보고체계의 적정성 등에 대한 견제·점검을 독립적으로 일관성 있게 수행
- 다. 전행적인 운영리스크 관리시스템을 구축·개선하고 이를 관리·감독하는 등 은행의 운영리스크 관리 기능을 질적으로 강화
- 라. 운영리스크를 인식·평가·감시·통제 및 경감할 수 있는 전략을 개발
- 마. 운영리스크 관리 및 통제와 관련하여 은행 내부의 정책 및 절차를 규정화
- 바. 은행의 운영리스크 평가·측정 방법론 및 운영리스크 관련 보고체계를 개발하고 이를 이행

9. **(3차 통제체계)** 내부감사는 다음의 역할을 수행하여야 하며, 단위사업부문 및 독립적인 운영리스크 관리부문에 대한 내부감사의 독립적인 점검 빈도 및 범위는 충분하면서도 여타 운영리스크 관리 기능과 부합하여야 한다. 한편, 외부조직에 의해 3차 통제체계가 작동되는 경우 경영진은 동 외부조직 활용의 효과성 및 적정성을 고려하여야 한다.

- 가. 각 단위사업부문의 활동 및 독립적인 운영리스크 관리부문에 대한 점검을 포함하여, 은행의 운영리스크 관리를 위한 통제체계, 프로세스 및 시스템에 대한 내부 정책과 절차가 효과적으로 마련·실행되는지 여부에 대하여 독립적으로 점검
- 나. 운영리스크 관리 체계가 당초 의도한 바대로 시행되고 있는지, 효과적으로 작동하고 있는지 등을 독립적으로 점검
- 다. 이사회가 승인한 정책·절차 및 운영리스크 관련 법규·내규·계약·행동강령 등의 준수 여부에 대한 점검
- 라. 감사업무 계획에 운영리스크 관리 체계에 대한 점검을 충실히 반영
- 마. 운영리스크 규제자본 산출의 적정성 및 리스크 성향·한도 등 준수 여부 점검
- 바. 단위사업부문의 경영진이 운영리스크 관련 사항에 대해 적시에 적절히 대응하고 이사회에게 정기적으로 보고하는지 여부 등을 포함하여 운영리스크 관리 체계에 대하여 전행적인 수준에서 단위사업부문 수준까지 점검
- 사. 입력값, 가정 등의 무결성이 보장되고 평가결과에 은행의 운영리스크 특성이 충실히 반영되도록 운영리스크 관련 계량평가 시스템의 적정성 및 독립성에 대해 점검

10. **(경영진 역할)** 경영진¹⁾은 이사회가 승인한 운영리스크 관리 체계를 운영할 책임이 있으며, 은행의 주요 상품, 활동, 절차 및 시스템 상의 운영리스크를 관리하는데 필요한 정책 및 절차 등을 마련하여야 한다. 또한, 경영진은 운영리스크 관리 수단의 발전 및 영업환경 변화 등에 대응하여 운영리스크 관리

1) 건전한 운영리스크 관리 원칙에서 사용하는 "이사회"와 "경영진"이라는 용어는 법적 구조가 아닌 은행 내 두 가지 의사결정 기능의 구조적 형태를 말한다.

체계 관련 정책, 프로세스 및 시스템이 충분히 견고하게 유지되도록 노력하여야 한다.

제3장 운영리스크 관리 기본원칙

11. **(리스크관리 문화)** 이사회와 경영진은 은행 전체에 견고한 리스크 관리 문화를 정착시키기 위한 책임이 있고 이를 위해 다음의 업무를 수행하여야 한다.

가. 이사회는 이사회 구성원을 포함한 임직원의 청렴성과 도덕성에 대한 명확한 기대를 바탕으로, 허용되거나 금지되는 행위 등을 명시한 복무규정 등을 수립하여야 한다. 이때, 복무규정 등에 대한 이행 수준은 이사회 또는 이사회로부터 권한을 위임받은 하위 위원회를 통해 점검되어야 하고 점검 결과는 은행 홈페이지 게시 등의 방법으로 공개되어야 한다.

나. 이사회 및 경영진은 리스크 성향, 한도, 장기적인 전략 방향, 재무 목표, 전반적인 안정성 및 건전성 등에 부합하고, 리스크와 보상간에 적절한 균형을 이루는 보상 정책을 마련하여야 한다.

다. 경영진은 적절한 수준의 운영리스크 교육이 단위 사업부문장, 내부통제 책임자 및 고위 관리자 등 조직 전반에 걸쳐 실시되도록 지원하여야 하며, 동 교육은 교육대상자의 역할과 책임 등에 맞게 실시되어야 한다.

라. 경영진은 임직원들이 리스크 관리와 관련하여 역할과 책임뿐만 아니라 이에 대한 권한을 충분히 이해할 수 있도록 내규 등에 임직원의 리스크 관리 관련 의무 등을 명확히 설정하여야 한다.

11의2. **(유인책 마련)** 은행은 전행적으로 운영리스크관리 개선을 장려하기 위한 유인책을 마련하여야 한다.

12. **(운영리스크 관리 체계)** 은행은 전반적인 리스크 관리 프로세스에 완전히 통합된 운영리스크 관리 체계를 개발, 시행 및 유지하여야 한다. 이때 은행의 규모, 복잡성 및 리스크 특성 등을 감안하여야 한다.

가. 은행의 운영리스크 관리 체계는 신규 추진 상품, 영업활동, 프로세스 및 시스템 뿐만 아니라 단위사업부문과 상위 부문을 포함하여 모든 수준에 걸친 리스크 관리 프로세스에 내재되어야 한다.

나. 은행은 운영리스크 평가 결과를 경영전략 수립시 반영하여야 한다.

다. 은행의 운영리스크 관리 체계는 운영리스크 관련 정책 및 절차를 참조하여 포괄적이고 적절하게 문서화 되어야 하며, 운영리스크 및 운영리스크 손실에 대한 정의를 포함하여 다음 사항을 명확히 반영하여야 한다.

(1) 운영리스크 관리를 위한 보고·결재선 및 책임 소재 등 통제구조

(2) 운영리스크 관련 위원회의 역할 및 구성원에 대한 요건

(3) 운영리스크 관련 평가 등의 수단 및 운영리스크 통제체계에서의 동 수단의 활용 방법과 이에 대한 역할 및 책임

(4) 운영리스크 성향 및 한도, 내재 및 잔여 리스크에 대한 최소 기준, 주요 리스크 유발 요인, 승인된 리스크 경감 기법 및 수단

- (5) 운영리스크의 효율적인 통제를 위한 통제 설계·구현 및 운영 방법 등에 관한 기본 방침
 - (6) 내재 및 잔여 운영리스크에 대한 한도 등을 설정하고 모니터링하기 위한 기본 방침
 - (7) 단위 사업부문에서 구현된 모든 유형의 운영리스크 및 통제 관련 목록 관리 방법
 - (8) 경영정보시스템(MIS: Management Information Systems) 구축 관련 사항
 - (9) 리스크 인식, 익스포저 평가 및 리스크관리 목표의 일관성을 확보하기 위한 공통적인 운영리스크 용어 체계
 - (10) 운영리스크 관리에 대한 적절한 독립적인 점검 및 평가
 - (11) 은행의 운영리스크 특성에 중요한 변화가 발생할 때마다 운영리스크 관리 체계를 점검하고 적절히 개선하기 위한 절차
13. **(운영리스크 평가시스템)** 은행의 운영리스크 평가시스템은 리스크관리시스템과 밀접하게 연계되어야 하며, 운영리스크 평가시스템의 산출물은 은행의 운영리스크 특성을 모니터링하고 통제하는 과정의 중요한 요소여야 한다.

제4장 지배구조

14. **(이사회의 리스크관리 체계 점검)** 이사회는 은행의 운영리스크관리에 대한 최종책임이 있으며, 운영리스크 관리 체계를 승인하고 이에 대해 정기적인 점검을 실시하여야 한다.
- 가. 이사회는 은행의 리스크관리 문화를 확립하고 이를 지원하는 프로세스를 통해 내부통제 환경에 대한 관리·감독을 수행하여야 한다.
 - 나. 이사회는 경영진에 대하여 운영리스크 관리 체계의 원칙 관련 명확한 지침을 제공하고 이에 따라 경영진이 마련한 동 체계를 승인하여야 한다.
 - 다. 이사회는 대외 여건 변화 및 신규 상품, 영업활동, 시스템 및 프로세스 등으로 인해 변화하는 리스크 특성을 인식하고 관리할 수 있도록 운영리스크 관리 체계를 정기적으로 점검하고 필요시 운영리스크 관리 체계를 개정·승인하여야 한다.
 - 라. 이사회는 운영리스크 관리 체계에 대한 내부감사의 독립적인 점검이 효과적으로 수행되고 있는지 확인하여야 한다.
 - 마. 이사회는 동종 업계의 우수사례가 은행의 운영리스크 관리 체계에 적절히 반영되고 있는지 확인하여야 한다.
 - 바. 이사회는 운영리스크 관리 기능, 사업 부문 및 지원 부서간 책임이 명확하게 구분된 견고한 내부통제 환경 조성을 위하여 각 부문별 책임을 독립적으로 명확하게 설정하여야 한다.
15. **(이사회의 리스크 성향 등의 점검)** 이사회는 정기적으로 리스크한도와 통제전략을 검토하고 전체 리스크 특성(profile)과 성향(appetite) 및 한도(tolerance) 등을 반영한 적절한 전략을 통하여 운영리스크

익스포저를 조정하여야 한다.

가. 이사회는 은행의 장단기 전략 및 재무 계획과 연계하여 단위 사업부문에서부터 진행에 걸쳐 일관되게 전반적인 운영리스크 성향 및 한도를 수립하고 이를 승인하여야 한다. 이때 운영리스크 성향 및 한도 정책은 미래 지향적이면서 모든 이해관계자가 이해하기 쉬워야 하며 다음을 명확히 반영하여야 한다.

(1) 은행의 사업계획 수립시 영향을 미친 주요 금융환경 등 배경 정보 및 가정

(2) 특정 유형의 리스크를 감수하거나 회피하려는 동기 및 이러한 리스크를 모니터링하기 위한 방법

(3) 적용 가능한 경우, 시나리오 또는 스트레스테스트 결과

나. 이사회는 대외 여건, 영업규모, 내부통제 환경 변화, 리스크 관리·경감 전략의 실효성, 실제 발생 손실 및 한도 초과 빈도와 규모·성격 등을 고려하여 경영진이 마련한 운영리스크 성향 및 한도의 적정성을 정기적으로 점검하여야 한다.

다. 이사회는 경영진이 리스크 성향 및 한도를 준수하고 있는지 점검하여야 하며, 이에 대한 미흡 사항이 발견된 경우 즉시 적절한 조치를 취하여야 한다.

16. (경영진의 역할과 책임) 경영진은 이사회가 승인한 운영리스크 관리 체계의 역할과 책임이 잘 정의되며 투명하고 일관되면서, 명확하고 효과적이며 견고하게 운영될 수 있도록 발전시켜야 하며, 전행적인 운영리스크 관리 정책, 프로세스 및 시스템을 지속적으로 시행·유지할 책임이 있다. 이때, 경영진은 다음의 책임이 있다.

가. 경영진은 견고한 견제 기능과 효과적인 문제 해결 프로세스를 수립·유지하여야 한다.

나. 경영진은 이사회가 승인한 운영리스크 관리 체계를 토대로 구체적인 정책 및 절차를 마련하여 운영리스크 관리 체계가 각 단위사업부문 내에서 이행될 수 있도록 하여야 한다.

다. 경영진은 운영리스크 관리를 위한 권한과 책임을 각 부문에 부여하여 보고 체계를 명확히 하여야 하며, 은행의 리스크 성향 및 한도에 상응하도록 운영리스크를 관리하기 위해 활용가능한 필요 자원을 확보하여야 한다.

라. 경영진은 운영리스크 관리 체계가 단위사업부문 활동에 내재된 리스크에 부합하도록 하여야 한다.

마. 경영진은 운영리스크 관리 담당자가 타 리스크 관리 담당자, 리스크 이전을 위한 보험가입 담당자 및 기타 외주 계약 담당자 등과 유기적인 협력 및 의사소통이 가능한 환경을 조성하여야 한다.

바. 은행은 독립적인 운영리스크 관리부문이 전행적인 수준에서 직무를 효과적으로 수행할 수 있도록 조직내 충분한 위상을 부여하여야 한다.

사. 독립적인 운영리스크 관리부문은 경력이 많은 직원으로 구성되어야 하며, 동 부문의 감독대상인 다른 부문으로부터 독립성을 유지하여야 한다.

아. 은행은 운영리스크 관리를 위한 지배구조를 구축할 때 은행의 성격, 규모, 복잡성 및 리스크 특성을 감안하되, 다음 사항을 반영하여야 한다.

- (1) 은행은 이사회내 위험관리위원회의 관리를 받는 운영리스크 관리를 위한 별도의 협의체(이하 "운영리스크관리협의체")를 운영하여야 한다.
- (2) 운영리스크관리협의체는 운영리스크 관리를 위한 주요 사항을 심의·의결하고 그 결과를 위험관리위원회에 보고 및 최종 승인 받아야 한다.
- (3) 운영리스크관리협의체는 영업, 재무, 법률, IT, 리스크관리 등 각 업무의 전문가로 구성되어야 하며, 이때 협의체 의장은 위험관리책임자로 한다.
- (4) 운영리스크관리협의체는 적절한 시기에 적절한 빈도로 개최되어야 하며 의사록은 충실히 작성되어야 한다.
- (5) 은행은 운영리스크관리협의체 개최 시기 및 방법, 보고·승인 등을 위한 안건 대상, 구성원 자격 요건 등을 포함한 운영리스크관리협의체 운영을 위한 사항을 규정한 내규를 마련하여야 한다.

16의2. (경영진의 운영리스크 관리 자원 확보) 경영진은 주요 영업영역, 통제 및 감사 부문에서 건전한 운영리스크 관리를 위한 충분한 자원을 확보하여야 한다.

제5장 리스크관리 환경

17. (리스크 인식·평가 대상) 경영진은 내재된 리스크와 인센티브가 명확히 이해될 수 있도록 내부 및 외부 요인들을 모두 고려하여 모든 주요 상품, 업무활동, 프로세스 및 시스템에 내재되어 있는 운영리스크를 인식하고 평가하여야 한다. 이를 위해 은행은 다음과 같은 수단을 활용할 수 있는데, 평가 수단은 무결성이 확보된 정확한 데이터에 기반하여 산출되어야 하고, 평가 결과는 사업성 평가뿐만 아니라 내부 가격 책정 및 성과 측정 방법 등에 있어 적절히 고려되어야 한다.

가. 내부 또는 외부 감사 결과를 통해 취약점을 확인한다.

나. 내부손실데이터 수집·분석을 통해 손실사건의 원인 및 내부통제 실패가 개별적인지 또는 구조적인 문제인지 파악하고, 신용·시장리스크 관련 손실에 대한 운영리스크 기여도를 분석·모니터링한다. 은행은 손실사건을 분석하기 위하여 <별표 3>의 <표 5> 세부 손실사건의 유형 분류에 따라 내부손실데이터를 분류하고 이를 외부손실데이터와 비교할 수 있다.

다. 은행 외부에서 발생한 운영리스크 손실사건 관련 손실금액, 발생일, 회수 및 관련 인과관계 정보를 수집하고 내부손실데이터와 비교하여 내부통제 취약점을 발견하고 새로운 리스크를 인식한다.

라. 잠재 리스크에 대응하여 은행의 주요 업무 프로세스에 내재된 리스크를 평가하기 위해 내부통제 반영 전 리스크(고유리스크), 내부통제 효과 및 내부통제 반영 후 리스크(잔여리스크)를 평가하는 등 리스크통제자가진단을 수행한다.

마. 주요 리스크와 관련된 익스포저 요인을 감시하기 위한 핵심리스크지표를 마련하고 리스크가 한도에 근접 또는 초과시 경고토록 한다.

바. 사업부문 및 리스크 관리 전문가 의견을 통해 은행의 운영리스크 특성을 잘 반영할 수 있도록 이용가능한 모든 정보를 포함하여 잠재적인 운영리스크 사건을 인식하기 위한 시나리오를 설정하고 이에 따른 결과를 평가한다. 은행은 운영리스크 시나리오를 은행의 종합적인 리스크평가지 활용한다.

사. 리스크 통제에 대한 모니터링 및 점검 체계 구축을 통해 통제 범위가 충분하도록 관리하고 통제가 인식된 리스크에 대해 적절히 설계되고 효율적으로 운영될 수 있도록 한다.

아. 내부손실 발생 빈도 등을 자가진단 결과와 비교하는 등 운영리스크 측정 결과를 분석하고 타사 지표와의 비교를 통해 은행의 운영리스크 프로파일에 대한 이해를 제고한다.

18. **(변경 관리)** 경영진은 새로운 상품, 업무, 서비스, 시장, 시스템, 프로세스 및 지점 개설 등 변경 사항과 관련한 운영리스크의 변화에 대해 인식·관리·점검·승인 등을 위한 변경 관리 정책 및 절차를 마련하여야 하며, 이러한 변경 관리는 상품의 전체 수명주기 동안 등과 같이 시작부터 종료때까지 기간 전반에 걸친 관련 리스크의 진화 과정을 평가하여야 한다.

가. 은행의 변경 사항은 변경 관리 정책 및 절차에 따라 1차 및 2차 통제체계에 의해 정기적으로 점검 및 관리되어야 한다. 이때, 단계별 통제체제의 역할과 책임은 다음과 같다.

(1) 1차 통제체계는 변경 사항에 대한 운영리스크 수준 및 통제활동에 대한 평가를 수행하여야 한다. 이때, 변경 사항에 대한 기획 단계부터 이행 및 사후 관리까지의 모든 단계에 있어 수반되는 변경사항에 대한 인식 및 평가를 포함한다.

(2) 2차 통제체계는 재무, 준법, 법무, 영업, ICT, 리스크 관리 등과 같은 통제 부서들을 활용하여 1차 통제체계에서 수행하는 변경 사항에 대한 운영리스크 수준 및 통제활동에 대한 평가 및 평가 후 조치사항에 대한 이행 현황을 점검하여야한다.

나. 은행은 변경 사항에 대한 점검 및 승인 프로세스를 규정하기 위한 정책과 절차를 마련하여야 하며, 동 점검 및 승인 프로세스는 다음 사항을 반영하여야 한다.

(1) 변경 사항을 도입하는데 있어 법률, ICT 및 모델리스크 등을 포함한 내재된 운영리스크

(2) 변경 사항 도입으로 인해 야기되는 기존 상품 또는 업무 등과 관련한 운영리스크 특성, 성향 및 한도 등의 변화

(3) 내부통제, 리스크 관리 프로세스 및 리스크 경감 전략

(4) 잔여리스크

(5) 리스크 임계치 또는 한도 변경

(6) 변경 사항에 대한 리스크 측정, 감시 및 관리를 위한 절차 및 측정방식

다. 점검 및 승인 프로세스에는 변경 사항이 도입되기 이전에 인적 자원 및 기술 인프라에 대한 적절한 투자가 있었는지 확인하는 절차가 포함되어야 한다.

라. 은행은 변경 사항이 도입된 이후의 동향을 감시하여 예상치 못한 리스크를 관리하여야 한다.

마. 은행은 변경 관리를 용이하게 하기 위해 상품·서비스 정보 등 변경 관리 관련 데이터를 관리하여 기록을 유지하여야 한다.

19. **(리스크 모니터링)** 경영진은 운영리스크 특성 및 운영리스크 관련 중요 익스포저를 정기적으로 감시하

기 위한 프로세스를 시행하여야 하며, 능동적인 운영리스크 관리를 위한 적절한 보고 체계가 이사회, 경영진 및 단위사업부문 수준에서 각각 수립·이행되어야 한다.

가. 은행은 운영리스크 보고서 작성시 포괄성, 정확성 및 일관성을 갖추고 여러 사업부문과 상품에 걸쳐 실현가능하면서 효과적인 조치를 취할 수 있도록 충분한 데이터를 활용하여야 한다.

나. 은행이 작성하는 운영리스크 보고서는 시의성이 있어야 한다.

다. 은행은 운영리스크 보고서 작성시 위기상황을 포함하여야 한다.

라. 은행의 운영리스크 보고 빈도는 영업환경 변화 및 관련 리스크를 감안하여야 한다.

마. 은행은 운영리스크 모니터링 결과를 경영진 및 이사회에 대한 정기 보고서에 반영하여야 한다.

바. 감독당국으로부터 통보된 운영리스크 관련 보고서는 은행의 경영진 및 이사회에 적절히 보고되어야 한다.

사. 은행은 운영리스크 보고서에 의사결정에 필요한 외부 시장에 대한 정보 및 내부적인 재무, 영업 및 규제 지표 뿐만 아니라, 1차 통제체계에서 점검한 운영리스크 사건 및 이와 관련한 통제 결함, 프로세스 미흡사항 및 잔여 리스크를 반영하여야 한다.

아. 은행이 운영리스크 보고서에 반영하여야 하는 기타 사항은 다음과 같다.

(1) 리스크 성향, 특성, 임계치, 한도 등에 대한 준수 여부 및 향후 준수 여부 전망

(2) 새롭게 대두되고 있는 주요 리스크

(3) 중요한 내부 손실사건 관련 세부사항

(4) 외부 사건 또는 규제 변화 등을 포함한 은행의 운영리스크에 영향을 미칠 수 있는 중요 사항

자. 은행은 운영리스크 관련 데이터 수집 및 리스크 보고 프로세스의 적정성을 정기적으로 점검하여 리스크 관리 방침 및 절차 등을 지속적으로 개선하여야 한다.

20. (통제 및 경감) 은행은 견고한 운영리스크 관리 체계 구축을 위해 적절한 정책, 프로세스, 내부통제 시스템, 리스크 경감 및 이전 전략 등을 수립하여야 한다.

가. 은행은 건전한 내부통제 시스템 구축을 위해 리스크 평가, 통제 활동, 정보교류, 모니터링 활동으로 구성된 리스크 관리 프로세스를 마련하여야 한다.

나. 운영리스크 관리를 위한 내부통제 프로세스 및 절차는 정책·규정·법령 등 준수를 위한 시스템 및 다음 사항을 포함하여야 한다.

(1) 수립된 목표 달성 수준에 대한 이사회 및 경영진의 점검

(2) 경영진으로부터의 통제를 준수하는지 여부 점검

(3) 규제 위반 사례에 대한 조치 및 해결방안 점검

(4) 승인 및 허가가 요구되는 사항에 대한 평가에 기초하여 당해 사항에 대한 책임을 적절한 수준의 관리자 책임으로 지정

(5) 한도 등에 대해 예외적으로 승인된 사항, 내규 등과 상충되는 경영진의 판단 및 기타 정책에서 벗어난 조치 등에 대한 추적 관리

다. 은행은 운영리스크 관리를 위한 효과적인 내부통제 환경을 구축하기 위해 적절히 직무를 분리하여야 하며 잠재적인 이해상충 가능성이 있는 영역을 인식 및 최소화하고 이에 대해 독립적인 점검을 실시하여야 한다.

라. 은행은 자동화된 업무 프로세스 등 기술과 관련하여 내재된 리스크를 인식·측정·평가·감시 및 관리하기 위해 운영리스크 관리와 동일한 방식으로 통합된 지배구조 및 리스크 관리 체계를 구축해야 한다.

마. 제3자에게 업무를 위탁하는 경우에도 건전한 운영리스크 관리 원칙이 적정하게 이행될 수 있도록, 이사회 및 경영진은 업무위탁과 관련한 운영리스크를 이해하여야 하고, 제3자 위탁에 따른 리스크 편중(제3자에 대한 전반적인 의존도, 제3자에 대한 종속성 포함)과 복잡성 등을 고려하여 업무위탁과 관련한 운영리스크를 관리하기 위한 효과적인 리스크 관리 정책 등을 마련하여야 한다. 이때, 리스크 관리 정책 등은 다음을 포함하여야 한다.

(1) 업무 위탁 가능 여부 평가 및 위탁 방법 등을 정하는 절차

(2) 업무 수탁자 선정을 위한 사전 실사 프로세스

(3) 데이터 소유권, 비밀유지 및 계약 종료 권한 등을 포함한 건전한 업무위탁 계약 체계

(4) 수탁업체의 재무상태 모니터링 등, 업무위탁 관련 리스크를 관리하고 모니터링하는 프로그램

(5) 수탁업체의 위탁업무 활동에 대한 평가 지표 및 보고체계 마련 등 수탁업체에 대한 효과적인 통제환경 구축

(6) 실행 가능한 비상 계획

(7) 위수탁 계약에 따른 책임 소재를 명확히 하기 위한 점검 체계

(8) 감독당국 등이 업무위탁 및 관련 운영리스크 관리 전반에 대한 수탁업체의 정보에 직접 접근할 수 있는 근거 확보

바. 경영진은 운영리스크 관리를 위한 내부통제체계를 보완하기 위하여 보험 등을 통해 리스크를 경감하는 방식을 활용할 수 있다. 이때, 리스크 경감 수단이 실제로 리스크를 경감시키는지, 다른 사업부문 등으로 리스크를 이전 시키지는 않는지, 또는 거래상대방 리스크 등과 같은 새로운 리스크를 발생시키지는 않는지 등을 검토하고 리스크 경감 수단을 활용해야 한다. 또한, 이사회는 은행이 수용 가능하면서 재무적으로 허용 가능한 최대 손실 익스포저를 결정하여야 하고, 매년 보험 등 리스크 경감 프로그램을 점검하여야 한다.

- 사. 은행은 2차 통제체계를 통해 운영리스크 관리와 관련한 분류 체계 및 방법론 등을 관리하여야 한다.
- 아. 이외에도, 은행은 운영리스크 관리를 위한 내부통제가 은행 전반에 걸쳐 적절히 수행될 수 있도록 다음 통제 방법들을 활용할 수 있다.
- (1) 승인과 관련한 권한 및 프로세스의 명확화
 - (2) 할당된 리스크 한도 준수 여부에 대한 감시
 - (3) 은행의 자산 및 관리내역에 대한 접근 및 활용 관련 안전장치
 - (4) 전문성을 유지하기 위해 직원에 대해 실시하는 적절한 교육
 - (5) 기대 이상으로 성과를 낸 사업부문 또는 상품을 인식하여 동 성과의 적정성을 점검하는 지속적인 프로세스
 - (6) 거래 및 계좌에 대한 정기적인 점검 및 조정
 - (7) 명령 휴가

제6장 정보통신기술 리스크관리

21. **(정보통신기술 리스크 관리)** 은행은 운영리스크 관리 체계에 따라 정보통신기술(ICT) 리스크²⁾를 관리하고 이를 경감하기 위해 노력해야 한다.

가. ICT 리스크는 정보통신기술과 관련한 직접적 손실, 평판 손상, 법적 청구, ICT 장애 및 기술의 오용 등을 포함하며, 은행은 리스크 성향 및 한도 정책에 따라 다음의 방법 등을 활용하여 이를 관리하여야 한다.

- (1) ICT 리스크 인식 및 평가
- (2) 사이버 보안, 대응 및 복구 프로그램, ICT 변경관리 프로세스, 사용자에게 관련 정보 적시 전송을 포함한 ICT 사고관리 프로세스 등 리스크 수준에 부합하는 경감 조치
- (3) 리스크 경감 조치에 대한 정기적인 테스트를 포함한 모니터링 체계

나. 정보통신기술을 통한 데이터 및 시스템의 기밀성, 무결성 및 가용성을 확보하기 위해 경영진은 은행의 ICT 리스크 관리의 설계, 이행 수준 및 효과성 등을 정기적으로 평가하고 이사회에 보고하는 방법으로 이사회의 감독을 받아야 한다. 이를 위해 은행은 ICT 리스크에 대해 상시 모니터링하고 미흡 및 개선 사항 등을 발굴하여 경영진에게 정기적으로 보고하는 체계를 구축하여야 한다.

다. 은행의 ICT 리스크 관리 및 이를 보완하기 위한 체계는 다음의 방법 등으로 관리되어야 한다.

- (1) 산업 표준 및 업계 모범 사례를 지속적으로 반영하고, 랜섬웨어 공격, 피싱 등 진화하는 사이버 위

2) 정보통신기술(Information and Communication Technology)은 은행의 운영을 지원하는 메커니즘 또는 상호 연결 네트워크의 일부를 구성하는 정보기술과 통신시스템, 개별 하드웨어와 소프트웨어 자산, 데이터, 그리고 운영 환경에 기반이 되는 물리적 및 논리적 설계를 말한다.

협과 새로운 기술 등에 완전히 대응하기 위해 정기적으로 점검되어야 한다.

- (2) 리스크 한도 소진 수준을 인식하고 리스크 관리 수준을 개선하기 위해 정기적으로 테스트 되어야 한다.
- (3) 정보통신기술 시스템, 네트워크 및 애플리케이션에 있어 취약점에 대한 탐지 능력을 지속적으로 향상시키고 리스크 및 변경 관리 등에 있어 효과적으로 의사결정을 하기위해 가능한 자원을 활용해야 한다.

라. 은행은 사이버 위협을 포함한 외부 사건들로 인해 업무 장애가 발생하는 스트레스 상황에 대비하여, 원격 사용자 접속 및 고객 데이터 보호를 위한 대응방안을 다음을 반영하여 마련해 두어야 한다.

- (1) 정보통신기술 시스템, 네트워크 및 애플리케이션의 장애 또는 손상과 관련한 잠재 리스크에 대한 적절한 리스크 경감 전략을 개발하고, 리스크 경감 전략을 통해 리스크 성향과 한도를 준수할 수 있는지 여부를 평가하여야 한다.
- (2) 사용자 권한 관리 및 애플리케이션 개발에 대한 명확한 프로세스를 수립하여야 한다.
- (3) 적절한 보안 수준을 유지하기 위해 사이버 보안 등 정보통신기술을 정기적으로 업데이트 하여야 한다.

제7장 영업연속성 계획 등

22. (영업연속성 계획 등) 은행은 심각한 업무상의 사고 발생에 따른 손실을 줄이고 은행이 지속적으로 영업할 능력이 있음을 확인하는 영업연속성계획(BCP: Business Continuity Plan)과 비상계획(Contingency Plan)을 운영리스크 관리 체계와 연계하여 마련하여야 한다.

가. 영업연속성계획 및 비상계획 등(이하 "영업연속성정책") 수립에 있어 이사회, 경영진, 3단계 통제체계 등의 역할은 다음과 같다.

- (1) 이사회는 영업연속성정책에 대한 주기적인 점검 및 승인을 담당하고, 경영진과 단위사업부문장은 영업연속성정책 이행을 주관한다.
- (2) 1차 및 2차 통제체계는 영업연속성정책 설계를 담당하고, 3차 통제체계는 이에 대한 점검을 수행한다.

나. 영업연속성정책은 은행의 핵심 업무 및 제3자 의존성 등에 영향을 미칠 수 있는 심각하지만 발생 가능한 시나리오 분석 및 이와 관련한 영향 분석과 복구 계획 등과 연계하여 발생 가능한 사건에 대비할 수 있도록 마련되어야 하며, 이때 다음 사항을 반영하여야 한다.

- (1) 영업연속성정책은 은행의 모든 단위사업부문에 대한 영향 뿐만 아니라 주요 업무 수탁업자 및 중앙은행·청산소 등 주요 거래 상대방에 대한 영향을 고려하여 수립되어야 한다.
- (2) 영업연속성정책 수립을 위한 시나리오는 재무, 운영, 법률 및 평판 등과 관련한 양적·질적 영향 평가 또는 영업 영향 분석(business impact analysis)을 반영하여야 한다.
- (3) 영업에 중대한 영향을 미치는 시나리오는 이와 관련한 영업연속성정책을 발동시키기 위한 임계치 또

는 한도 등을 반영해야 하며, 이때의 영업연속성정책은 업무재개를 위한 복구 시간 및 복구 지점 뿐만 아니라 임직원·감독당국·이해관계자 등에게 관련 정보를 공유하기 위한 체계를 포함하여야 한다.

- 다. 은행은 영업연속성정책을 주기적으로 점검 하여 현재의 영업환경 및 리스크 요인 등을 적절히 반영하도록 하여야 하고, 임직원이 비상시 비상계획 등을 충분히 이행할 수 있도록 역할에 따라 적절한 교육 등을 제공하여야 하며, 가능하면 수탁업체를 포함하여 영업연속성에 대한 테스트를 주기적으로 실시하여 업무 복구 및 재개 목표와 기간을 준수하는지 여부를 확인하고 이에 대한 결과를 경영진 및 이사회에 보고하여야 한다.

제8장 공시

23. (공시) 은행이 공시한 정보는 이해관계자가 은행의 운영리스크 관리 체계에 대해 평가하기에 충분하여야 한다.

가. 은행은 조직의 규모와 리스크 특성, 복잡성 등을 충분히 반영하여 운영리스크 관련 정보를 공시하여야 한다.

나. 은행은 운영리스크 관련 정보 공시를 통해 이해관계자가 은행의 운영리스크 인식, 평가, 감시, 통제 및 경감 체계의 효과적인 작동 여부를 확인할 수 있도록 하여야 한다.

다. 은행은 운영리스크 공시 절차 및 이를 위한 내부통제 등 운영리스크 공시 기준을 수립하여야 하며 이에 대해 이사회 승인을 받아야 한다.

라. 은행은 공시 내용 및 주기의 적정성에 대해 자체적으로 점검하는 절차를 수립하여야 한다.

[시행일: 2024.1.1.]